Active Directory Security Audit Report

Kurum: NordActive Holding

Executive Summary

NordActive Holding'in Active Directory ortamına yönelik gerçekleştirilen güvenlik denetiminde, yönetim beyanları ile teknik kanıtlar arasında ciddi uyumsuzluklar tespit edilmiştir. Ayrıcalıklı erişim yönetimi, şifre politikaları, grup ilkesi delegasyonu ve kimlik yaşam döngüsü alanlarında temel kontrol eksiklikleri bulunmaktadır. Özellikle sözleşmesi bitmiş bir taşeron hesabıyla sistemlere yakın zamanda giriş yapılmış olması, aktif bir güvenlik ihlali şüphesi doğurmaktadır. Tespit edilen bulgular, kurumun fidye yazılımı ve yetki yükseltme saldırılarına karşı yüksek risk altında olduğunu göstermektedir.

Scope

Bu denetimin kapsamı, uzun yıllardır kullanılmakta olan nordactive.local forest/domain mimarisi ve bu yapıya bağlı seçili sistemlerdir.

Procedures Performed

Sistem sahiplerinin beyanları alınmış, 3 Haziran 2026 tarihinde "read-only audit account" ile sistemden toplanan yapılandırma, kullanıcı ve grup üyelik kanıtları bu beyanlarla karşılaştırılmıştır. Teknik ve idari çelişkiler tespit edilerek risk değerlendirmesi yapılmıştır.

FINDINGS (BÖLÜM 1 - CRITICAL & HIGH)

Finding ID: AD-01 / Aktif Güvenlik İhlali Şüphesi ve Taşeron Hesap Yönetimi Zafiyeti

- **Condition:** Sözleşmesi 31 Mart 2025 tarihinde sona ermiş olan vendor03 isimli dış kaynak hesabının açık bırakıldığı ve bu hesap ile 1 Haziran 2026 tarihinde (sözleşme bitiminden 14 ay sonra) sisteme giriş (LastLogon) yapıldığı tespit edilmiştir. Ayrıca, hesabın parolası süresiz (NeverExpires: True) olarak ayarlanmıştır.
- **Criteria:** Yönetim beyanı gereği "eski aktif hesap bulunmaz" ve erişimler periyodik olarak doğrulanmalıdır.
- **Risk / Impact:** Aktif exploitation (sömürü) ve yetkisiz erişim riski gerçekleşmiştir. Dış kaynak veya yetkisiz kişiler şirket ağına erişim sağlamıştır (Data Breach).
- **Root Cause:** Mayıs 2024'ten beri periyodik erişim gözden geçirmelerinin (Quarterly Access Review) yapılmaması ve İK/Satınalma süreçleri ile AD arasında offboarding entegrasyonunun olmaması.

- **Evidence:** EV-05 (Access Review durumu), EV-11 (vendor03 kontrat ve logon bilgisi).
- **Recommendation:**
    - *Immediate Action:* vendor03 hesabı derhal devre dışı bırakılmalı ve hesabın 1 Haziran 2026'daki hareketleri SIEM üzerinden incelenerek Incident Response süreci başlatılmalıdır.
    - *Preventive:* Taşeron sözleşmeleri bitiminde AD hesaplarını otomatik kilitleyecek mekanizmalar kurulmalıdır.
- **Risk Rating: Critical** (Active exploitation riski).
- **Management Action / Owner:** CISO & IT Operations / Derhal (Immediate).

Finding ID: AD-02 / Servis Hesaplarında Kriptografi Zafiyeti ve Yetki Aşımı (Kerberoasting)

- **Condition:** Yedekleme işlemlerinden sorumlu svc_backup servis hesabının "Domain Admins" grubuna üye yapıldığı, şifresinin 2021 yılından beri değiştirilmediği ve AES şifrelemesi kapalıyken eski/zayıf RC4 şifrelemesi kullandığı tespit edilmiştir. Ayrıca svc_sql hesabı da zayıf RC4 algoritması kullanmaktadır.
- **Criteria:** Yönetim beyanına göre "Servis hesapları güvenli parola, sınırlı yetki ve güçlü kriptografiyle korunur". Endüstri standartları gereği servis hesapları Domain Admin olmamalı ve AES kriptografisi kullanmalıdır.
- **Risk / Impact:** Saldırganlar ağa sızdığında, Kerberoasting saldırısı ile RC4 ile şifrelenmiş servis biletlerini çevrimdışı kırarak şifreleri ele geçirebilir. svc_backup hesabının ele geçirilmesi, domain'in tamamen ele geçirilmesine (Domain Compromise) yol açacaktır.
- **Root Cause:** "En Az Ayrıcalık" prensibinin ihlali ve servis hesapları için güvenli şifre rotasyonu / hardening prosedürlerinin eksikliği.
- **Evidence :** EV-03, EV-06, EV-12.
- **Recommendation:** svc_backup hesabı derhal Domain Admins grubundan çıkartılmalı ve yalnızca Backup Operators yetkisi ile sınırlandırılmalıdır. Tüm servis hesaplarında (özellikle svc_backup ve svc_sql) RC4 desteği kapatılıp AES256 zorunlu kılınmalı ve şifreler yenilenmelidir.
- **Risk Rating: Critical** (Çok ciddi privileged access ve domain compromise riski).
- **Management Action / Owner:** IT Infrastructure Manager / 1 Hafta İçerisinde.

Finding ID: AD-03 / Default Domain Policy Üzerinde Tehlikeli Delegasyon

- **Condition:** Kurumun en kritik grup ilkesi olan "Default Domain Policy" üzerinde, sadece son kullanıcılara destek vermekle görevli Helpdesk Team grubuna ayarları değiştirme, güvenlik yetkilerini düzenleme ve uygulama yetkilerinin verildiği görülmüştür.
- **Criteria:** Yönetim beyanı gereği GPO'lar "yalnız yetkili ekiplerce değiştirilebilir" olmalıdır. Helpdesk'in domain politikası değiştirme yetkisi bulunmamalıdır.
- **Risk / Impact:** Yardım masası personelinden birinin hesabının ele geçirilmesi durumunda, saldırgan tüm domain ortamındaki bilgisayarlara ve sunuculara (Domain Controllers dahil) zararlı yazılım dağıtabilir veya güvenlik politikalarını devre dışı bırakabilir.
- **Root Cause:** Geçmişte yanlış yapılandırılmış bir yetki devri ve bu delegasyonların düzenli olarak denetlenmemesi.
- **Evidence :** EV-09
- **Recommendation:** Helpdesk Team grubunun Default Domain Policy üzerindeki yazma ve düzenleme yetkileri derhal geri alınmalı, sadece "Read" yetkisi bırakılmalıdır.
- **Risk Rating: Critical** (Çok ciddi privilege escalation riski).
- **Management Action / Owner:** Directory Services Admin / 3 Gün İçerisinde.

Finding ID: AD-04 / Domain Controller Mimarisinde Tek Nokta Hatası (Single Point of Failure)

- **Condition:** Yönetim, ortamda birden fazla güncel domain controller (DC) bulunduğunu ("domain controller'lar") beyan etmesine rağmen, Active Directory mimarisinde kimlik doğrulama hizmeti veren yalnızca tek bir Domain Controller (DC01.nordactive.local) olduğu tespit edilmiştir.
- **Criteria:** İş sürekliliği gereksinimleri ve best-practice'lere göre, kesintisiz kimlik doğrulama için en az iki adet DC bulunmalıdır.
- **Risk / Impact:** Mevcut DC01 sunucusunda yaşanacak donanımsal bir arıza veya fidye yazılımı saldırısı sonucunda, tüm holding çalışanlarının sisteme giriş yapamaması ve iş sürekliliğinin tamamen durması.
- **Root Cause:** BT altyapı planlama eksikliği veya mevcut diğer DC'lerin uzun süredir arızalı/ kapalı olması ve izlenmemesi.
- **Evidence:** EV-01.
- **Recommendation:** Ortama derhal ikincil bir Domain Controller (Additional DC) kurularak replikasyon mimarisi oluşturulmalı ve sunucu sağlığı aktif olarak izlenmelidir.
- **Risk Rating: High** (Temel kontrol eksikliği).

- **Management Action / Owner:** BT Altyapı Direktörü / 1 Ay İçerisinde.

Finding ID: AD-05 / İşten Ayrılan Personel Hesaplarının Kapatılmaması (Offboarding Zafiyeti)

- **Condition:** İnsan Kaynakları kayıtlarında işten ayrıldığı görülen Fatma Arslan (07.02.2025 tarihinde ayrıldı) ve Hakan Yıldız'ın (15.01.2025 tarihinde ayrıldı) Active Directory üzerindeki kullanıcı hesaplarının 3 Haziran 2026 tarihi itibarıyla hâlâ aktif (Enabled: True) durumda olduğu tespit edilmiştir.
- **Criteria:** Yönetim beyanı ve kurum politikası gereği, ayrılan çalışan hesaplarının en geç 24 saat içinde kapatılması gerekmektedir.
- **Risk / Impact:** İşten ayrılan eski personellerin kurumsal sistemlere, hassas finansal ve operasyonel verilere yetkisiz erişim sağlaması riski bulunmaktadır.
- **Root Cause:** İK sistemi ile Active Directory arasında otomatik bir hesap kapama entegrasyonunun olmaması ve manuel süreçlerdeki takip eksiklikleri.
- **Evidence :** EV-02 (AD User Properties & HR Extract), EV-05.
- **Recommendation:** Ayrılan personellerin hesapları derhal kapatılmalı; İK ile IT birimleri arasında otomatik hesap yaşam döngüsü entegrasyonu sağlanmalıdır.
- **Risk Rating: High** (Önemli temel kontrol eksikliği).
- **Management Action / Owner:** İK Direktörlüğü & IT Sistem Yöneticiliği / 3 Gün İçerisinde.

Finding ID: AD-06 / Hesap Kilitleme (Account Lockout) Mekanizmasının Devre Dışı Olması

- **Condition:** Active Directory varsayılan etki alanı politikasında hesap kilitleme eşiğinin (Lockout Threshold) **0 (sıfır)** olarak ayarlandığı, yani başarısız giriş denemelerine rağmen hesapların otomatik olarak kilitlenmediği tespit edilmiştir.
- **Criteria:** Yönetim beyanına göre "başarısız girişler otomatik sınırlandırılır". Güvenlik en iyi uygulamaları, kaba kuvvet (Brute-Force) saldırılarına karşı eşik değerinin tanımlanmasını zorunlu kılar.
- **Risk / Impact:** Kötü niyetli aktörlerin veya botnetlerin şifre deneme (Brute-Force / Password Spraying) saldırılarını hiçbir engelle karşılaşmadan sınırsızca yapabilmesine zemin hazırlanmaktadır.
- **Root Cause:** Güvenlik yapılandırma standartlarının yanlış uygulanması veya ihmal edilmesi.
- **Evidence:** EV-08 (Search-ADAccount -LockedOut & Policy).
- **Recommendation:** Hesap kilitleme eşiği kurum risk iştahına uygun olarak (örneğin 5 hatalı deneme) acilen etkinleştirilmelidir.

- **Risk Rating: High**.
- **Management Action / Owner:** IT Security Team / 1 Hafta İçerisinde.

Finding ID: AD-07 / Periyodik Erişim Gözden Geçirmelerinin (Access Review) Yapılmaması

- **Condition:** Üç aylık periyodik erişim gözden geçirmelerinin en son 12 Mayıs 2024 tarihinde yapıldığı, bir sonraki dönemin 12 Ağustos 2024 olmasına rağmen durumun "Pending" (Beklemede) kaldığı ve denetim tarihi olan Haziran 2026'ya kadar yaklaşık 2 yıldır yeni bir gözden geçirme yapılmadığı tespit edilmiştir.
- **Criteria:** Yönetim beyanı gereği "Grup üyelikleri rol bazlıdır ve periyodik review ile doğrulanır".
- **Risk / Impact:** Yetkisi kalmaması gereken kişilerin sistemlerde ayrıcalıklı erişimlerini sürdürmesi ve yetim hesapların denetlenememesi.
- **Root Cause:** Erişim yönetişimi süreçlerinin sahiplenilmemesi ve otomatize edilmemiş manuel takip sistemleri.
- **Evidence:** EV-05
- **Recommendation:** Erişim gözden geçirme süreçleri yeniden yapılandırılmalı, üç aylık periyotlar halinde acilen tamamlanarak yönetim onayına sunulmalıdır.
- **Risk Rating: High**.
- **Management Action / Owner:** Altyapı Yönetimi & Bilgi Güvenliği / 1 Ay İçerisinde.

Finding ID: AD-08 / İK Delegasyon Grubunda Geçici Hesap Bulunması

- **Condition:** Users OU'su üzerinde HR-IT-Coordinators grubuna kullanıcı oluşturma ve silme (CreateChild, DeleteChild) yetkisi verilmiştir. Ancak bu grubun üyeleri arasında geçici bir proje hesabı olan temp.hrproject yer almaktadır.
- **Criteria:** En az ayrıcalık ve görevler ayrılığı ilkeleri gereği, geçici hesaplara kritik yönetimsel delegasyonlar verilmemelidir.
- **Risk / Impact:** Geçici bir proje hesabının ele geçirilmesi veya kötüye kullanılması durumunda, yetkisiz kişilerin Active Directory üzerinde hesap yaratması veya mevcut kritik kullanıcıları silmesi riski doğar.
- **Root Cause:** Geçici hesapların yaşam döngüsü ve yetki sınırlandırmalarının denetlenmemesi.
- **Evidence:** EV-10 (OU & Delegated Permissions).
- **Recommendation:** temp.hrproject hesabı derhal bu gruptan çıkarılmalı ve geçici hesapların yetkilendirme politikaları sıkılaştırılmalıdır.

- **Risk Rating: High**.
- **Management Action / Owner:** IT & İK Operasyonları / Hemen.

Finding ID: AD-09 / Desteklenmeyen (End-of-Life) İşletim Sistemi Kullanımı

- **Condition:** Üretim ortamında bulunan FILE-OLD sunucusunda desteği Ekim 2023'te bitmiş olan Windows Server 2012 R2 işletim sisteminin çalıştırıldığı tespit edilmiştir.
- **Criteria:** Yönetim beyanına göre "Bağlı sistemler desteklenen sürümlerde ve baseline altında çalışır".
- **Risk / Impact:** Destek süresi biten sistemler güvenlik yaması almadığından, bilinen güvenlik açıklarının (CVE) istismar edilmesi ve fidye yazılımlarının hedefi olması kaçınılmazdır.
- **Root Cause:** Eski sistemlerin modernizasyon planlarının yapılmamış olması.
- **Evidence:** EV-13 (Platform Security / OS Inventory).
- **Recommendation:** FILE-OLD sunucusu acilen desteklenen bir işletim sistemine (Windows Server 2022 vb.) yükseltilmeli veya hizmet dışı bırakılmalıdır.
- **Risk Rating: High**.
- **Management Action / Owner:** BT Altyapı Ekibi / 2 Ay İçerisinde.

Observations (Gözlem ve İyileştirme Fırsatları)

- **(Karantina Kontrolü - EV-13):** Desteklenmeyen Windows XP Professional işletim sistemi kullanan WS-XP01 cihazının Active Directory'de kayıtlı olduğu ancak şirket ağından (corporate VLAN) ağ düzeyinde ACL ile izole edilerek başarılı bir karantina (deny corporate VLAN) uygulandığı görülmüştür. Bu başarılı bir telafi edici kontrol olmakla birlikte, cihazın tamamen domain ortamından çıkartılması önerilir.
- **Acil Durum Hesabı - EV-11):** Acil durum (Breakglass) hesabı olan breakglass01 hesabının şifresinin kasada (vaulted) saklandığı ve 2 Mayıs 2026 tarihinde test kanıtının oluşturulduğu tespit edilmiştir. Bu durum iyi bir uygulama (Good Practice) olarak değerlendirilmiştir.